

PortSwigger 08

▼ Lab: Username enumeration via different responses

This lab is vulnerable to username enumeration and password brute-force attacks. It has an account with a predictable username and password, which can be found in the following wordlists:

- [Candidate usernames](#)
- [Candidate passwords](#)

To solve the lab, enumerate a valid username, brute-force this user's password, then access their account page.

Solution

1. With Burp running, investigate the login page and submit an invalid username and password.
2. In Burp, go to **Proxy > HTTP history** and find the `POST /login` request. Highlight the value of the `username` parameter in the request and send it to Burp Intruder.
3. In Burp Intruder, notice that the `username` parameter is automatically set as a payload position. This position is indicated by two `$` symbols, for example: `username=$invalid-username$`. Leave the password as any static value for now.
4. Make sure that **Sniper attack** is selected.
5. In the **Payloads** side panel, make sure that the **Simple list** payload type is selected.
6. Under **Payload configuration**, paste the list of candidate usernames. Finally, click **Start attack**. The attack will start in a new window.
7. When the attack is finished, examine the **Length** column in the results table. You can click on the column header to sort the results. Notice that one of the entries is longer than the others. Compare the response to this payload with the other responses. Notice that other responses contain the

message `Invalid username`, but this response says `Incorrect password`. Make a note of the username in the **Payload** column.

8. Close the attack and go back to the **Intruder** tab. Click **Clear**, then change the `username` parameter to the username you just identified. Add a payload position to the `password` parameter. The result should look something like this: `username=identified-user&password=$invalid-password$`
9. In the **Payloads** side panel, clear the list of usernames and replace it with the list of candidate passwords. Click **Start attack**.
10. When the attack is finished, look at the **Status** column. Notice that each request received a response with a `200` status code except for one, which got a `302` response. This suggests that the login attempt was successful - make a note of the password in the **Payload** column.
11. Log in using the username and password that you identified and access the user account page to solve the lab.

Note

It's also possible to brute-force the login using a single cluster bomb attack. However, it's generally much more efficient to enumerate a valid username first if possible.

▼ Lab: Username enumeration via subtly different responses

This lab is subtly vulnerable to username enumeration and password brute-force attacks. It has an account with a predictable username and password, which can be found in the following wordlists:

- [Candidate usernames](#)
- [Candidate passwords](#)

To solve the lab, enumerate a valid username, brute-force this user's password, then access their account page.

Solution

1. With Burp running, submit an invalid username and password. Highlight the `username` parameter in the `POST /login` request and send it to Burp Intruder.
2. Go to **Intruder**. Notice that the `username` parameter is automatically marked as a payload position.
3. In the **Payloads** side panel, make sure that the **Simple list** payload type is selected and add the list of candidate usernames.
4. Click on the **Settings** tab to open the **Settings** side panel. Under **Grep - Extract**, click **Add**. In the dialog that appears, scroll down through the response until you find the error message `Invalid username or password.`. Use the mouse to highlight the text content of the message. The other settings will be automatically adjusted. Click **OK** and then start the attack.
5. When the attack is finished, notice that there is an additional column containing the error message you extracted. Sort the results using this column to notice that one of them is subtly different.
6. Look closer at this response and notice that it contains a typo in the error message - instead of a full stop/period, there is a trailing space. Make a note of this username.
7. Close the results window and go back to the **Intruder** tab. Insert the username you just identified and add a payload position to the `password` parameter: `username=identified-user&password=$invalid-password$`
8. In the **Payloads** side panel, clear the list of usernames and replace it with the list of passwords. Start the attack.
9. When the attack is finished, notice that one of the requests received a `302` response. Make a note of this password.
10. Log in using the username and password that you identified and access the user account page to solve the lab.

Note

It's also possible to brute-force the login using a single cluster bomb attack. However, it's generally much more efficient to enumerate a valid username first if possible.

▼ Lab: Username enumeration via response timing

This lab is vulnerable to username enumeration using its response times. To solve the lab, enumerate a valid username, brute-force this user's password, then access their account page.

- Your credentials: `wiener:peter`
- Candidate usernames
- Candidate passwords

Hint

To add to the challenge, the lab also implements a form of IP-based brute-force protection. However, this can be easily bypassed by manipulating HTTP request headers.

Solution

1. With Burp running, submit an invalid username and password, then send the `POST /login` request to Burp Repeater. Experiment with different usernames and passwords. Notice that your IP will be blocked if you make too many invalid login attempts.
2. Identify that the `X-Forwarded-For` header is supported, which allows you to spoof your IP address and bypass the IP-based brute-force protection.
3. Continue experimenting with usernames and passwords. Pay particular attention to the response times. Notice that when the username is invalid, the response time is roughly the same. However, when you enter a valid username (your own), the response time is increased depending on the length of the password you entered.
4. Send this request to Burp Intruder and select **Pitchfork attack** from the attack type drop-down menu. Add the `X-Forwarded-For` header.
5. Add payload positions for the `X-Forwarded-For` header and the `username` parameter. Set the password to a very long string of characters (about 100 characters should do it).

6. In the **Payloads** side panel, select position **1** from the **Payload position** drop-down list. Select the **Numbers** payload type. Enter the range 1 - 100 and set the step to 1. Set the max fraction digits to 0. This will be used to spoof your IP.
7. Select position **2** from the **Payload position** drop-down list, then add the list of usernames. Start the attack.
8. When the attack finishes, at the top of the dialog, click **Columns** and select the **Response received** and **Response completed** options. These two columns are now displayed in the results table.
9. Notice that one of the response times was significantly longer than the others. Repeat this request a few times to make sure it consistently takes longer, then make a note of this username.
10. Create a new Burp Intruder attack for the same request. Add the **X-Forwarded-For** header again and add a payload position to it. Insert the username that you just identified and add a payload position to the **password** parameter.
11. In the **Payloads** side panel, add the list of numbers to payload position 1 and add the list of passwords to payload position 2. Start the attack.
12. When the attack is finished, find the response with a **302** status. Make a note of this password.
13. Log in using the username and password that you identified and access the user account page to solve the lab.

Note

It's also possible to brute-force the login using a single cluster bomb attack. However, it's generally much more efficient to enumerate a valid username first if possible.